

****Supervision of Notification of Breach of Personal Data Security****

Date: 31-08-2023

****Decision****

Public Authorities

No Criticism

Supervision / Self-initiated Case

Notification of Breach of Personal Data Security

The Danish Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of personal data security. The Agency found reason to express criticism in two cases.

Journal Number: 2021-423-0241.

Hedensted Municipality was among the public authorities that the Danish Data Protection Agency selected for supervision in the spring of 2021 under the General Data Protection Regulation [1] and the Data Protection Act [2].

The Agency's supervision was a written inspection that focused on whether Hedensted Municipality had implemented appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, aimed at reducing the number of breaches of personal data security involving unauthorized disclosure of personal data, including in relation to citizens with name and address protection.

The supervision was announced in a letter dated June 21, 2021, to Hedensted Municipality, which was also requested to respond to a series of questions and to submit an example of an instruction to the municipality's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc.

The Danish Data Protection Agency informed that, during a review of the Agency's cases concerning notifications of breaches of personal data security, it could be established that Hedensted Municipality had reported significantly more breaches of personal data security per inhabitant in the municipality than other municipalities in Denmark.

The Agency noted in this context that the higher number of notifications does not necessarily indicate that the municipality complies with data protection regulations to a lesser extent than municipalities with significantly fewer notifications per inhabitant.

In a letter dated August 9, 2021, Hedensted Municipality sent a statement in response to the Danish Data Protection Agency's questions. The municipality's response was also accompanied by examples of relevant procedures and guidelines.

****Summary****

In the summer and autumn of 2021, the Danish Data Protection Agency initiated written inspections of the handling of breaches of personal data security by eight larger municipalities and eight larger banks. The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the respective municipality's population and the number of employees in the bank.

"One of the new things that came with GDPR over five years ago was that data controllers, as a rule, must report all breaches of personal data security to the Danish Data Protection Agency within 72 hours, and they must internally document all breaches of personal data security, regardless of whether they need to be reported to the Agency or not. Additionally, there has been an increased focus on what companies and authorities must consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, Chief Consultant at the Danish Data Protection Agency, and continues: "This may, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is broadly that the 16 selected municipalities and banks appear to have the right focus on complying with the rules."

****Group with the Most Reported Breaches****

For the group with the most reported breaches, the inspections focused on whether the municipalities

and banks had implemented appropriate security measures aimed at reducing the number of breaches of personal data security where unauthorized disclosure of personal data occurred in connection with the transmission of information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons. The data controller must, in this context, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Danish Data Protection Agency found, based on the available information, that all data controllers had implemented appropriate security measures. In its assessment, the Agency emphasized that: Procedures, etc., had been developed and activities conducted to educate employees in data protection, including to ensure that they are aware that there should be no accidental disclosure of personal data to an incorrect recipient.

They have made considerations and continuously implemented both

****Technical and Organizational Measures in Extension of Past Breaches of Personal Data Security to Avoid Similar Breaches.****

There is a strong focus on avoiding unintentional disclosure of confidential information, which is supported by business processes, ongoing guidance, etc., as well as systematic measures, etc.

****The Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's view that compliance with the rules stipulating that breaches of personal data security must, in principle, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are adequately familiar with internal procedures for handling breaches of personal data security, and that relevant employees can identify, manage, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented appropriate training activities that can support compliance with the requirements of the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization, so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including, among other things, the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity, as part of the inspection, to take a specific position on whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security has been complied

with. Therefore, data controllers should document their justifications for all significant decisions made as a result of the breach. This is particularly relevant if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in Two Cases****

As mentioned, there is pronounced criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality has identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to gain an overview of which breaches typically occur in the organization, and based on that, to consider whether, from a risk assessment, there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It also appears from the received consultation responses that several data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds, based on the existing information, that Hedensted Municipality has taken appropriate security measures in accordance with Article 32, paragraph 1, of the General Data Protection Regulation, with the aim of reducing the number of breaches of personal data security, where unauthorized disclosure of personal data occurs, including in relation to citizens with name and address protection.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

It is stated in Article 32, paragraph 1, of the General Data Protection Regulation that the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing of personal data.

The data controller is thus obligated to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. The Data Protection Authority believes that the requirement under Article 32 for appropriate security will generally imply that the data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons, and that the data controller must, in this regard, ensure that all employees in the organization are adequately familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc., and that procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

Hedensted Municipality, in its statement of August 9, 2021, submitted an example of an instruction to the municipality's employees regarding the transmission of personal data to, among others, citizens, authorities, etc. Hedensted Municipality has stated that considerations regarding the protection of name and address information are a natural part of the processing of personal data throughout the municipality. It is noted that it is implicit in the understanding of good data processing practices and behavior to ensure extra protection when name and address protection is desired. Should there be an accidental disclosure of information about individuals with name and address protection, it will be handled promptly and will always – if possible – trigger a telephone contact with the affected

individuals. The municipality will also seek to identify the cause in order to learn from it and thus avoid similar incidents. The municipality is therefore particularly aware that such disclosure may lead to a potentially dangerous situation for the affected individuals.

Furthermore, the municipality has stated that ongoing measures are being implemented to avoid repetitions of breaches of personal data security, where accidental disclosures occur. Hedensted Municipality has indicated that specific incidents are discussed with the individual employee in order to establish further measures that can prevent recurrences. In the event of repetitions in a department, the municipality's data protection advisor is involved in a dialogue with the department to avoid future incidents.

It further appears from the case that Hedensted Municipality has reflected on past breaches of personal data security, where there has been accidental disclosure of personal data. Based on these reflections, the municipality has continuously implemented organizational measures, such as establishing a group that screens access requests before transmission. Furthermore, the municipality has implemented technical measures, including the purchase of a scanning tool designed to properly obscure documents containing personal data. Hedensted Municipality has also stated that the municipality continuously implements technical and organizational measures aimed at reducing the number of breaches of personal data security, where accidental disclosures of personal data occur.

It is – despite the fact that the Data Protection Authority has not had the opportunity to take a specific position on whether the municipality has been in dialogue with all relevant employees and departments, and that the authority is not aware of the full content of all training materials, etc. – based on the information available, the authority's assessment that Hedensted Municipality has taken appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, aimed at reducing the number of breaches of personal data security, where unauthorized disclosure of personal data occurs, including in relation to citizens with name and address protection.

In its assessment, the Data Protection Authority has emphasized the information provided by the municipality, including that procedures have been developed for the transmission of personal data to external parties, that the municipality has reflected on and implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches, and that there is a strong focus on avoiding accidental disclosures of name and address protected information.

The Data Protection Authority can, upon a renewed review of the authority's cases regarding reports of breaches of personal data security, ascertain that since June 22, 2021, there has been a decrease in the number of reported breaches of personal data security from Hedensted Municipality. However, as a number of breaches of personal data security continue to be reported, where unauthorized disclosure of personal data has occurred, the Data Protection Authority recommends that the municipality continues to focus on implementing training and awareness activities, etc., as well as ensuring that procedures, guidelines, workflows, technical security measures, etc., are continuously updated or introduced, including as a result of identified breaches of personal data security.

Finally, the Data Protection Authority notes that the authority – typically if it receives new reports of breaches of personal data security – may resume the processing of previously reported breaches or include them in the assessment of any future breach or complaint cases.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)